



Seguridad en **Imágenes de Contenedores**

Sesión 2

Agenda

- 1.Introducción a la seguridad en contenedores.
- 2.Seguridad en el ciclo de vida de contenedores.
- 3.Capacidades de Linux y su impacto en seguridad.
- 4.Herramientas de escaneo de vulnerabilidades.
- 5.Prácticas para construir imágenes seguras.
- 6.Políticas de seguridad en CI/CD.
- 7.Conclusión y preguntas.



Introducción a Seguridad en Contenedores

- **Definición:** Contenedores como plantillas para aplicaciones (SO, bibliotecas, dependencias).
- **Riesgos:** Vulnerabilidades heredadas, exposición de datos, escalada de privilegios.
- **Objetivo:** Garantizar integridad, confidencialidad y disponibilidad. **Imagen Referenciada:** [Figura 1: Capas de una imagen Docker] (Nota: Indicar que se incluye gráfico).

Ciclo de Vida de Contenedores

1. Creación: Imágenes base confiables y actualizadas.

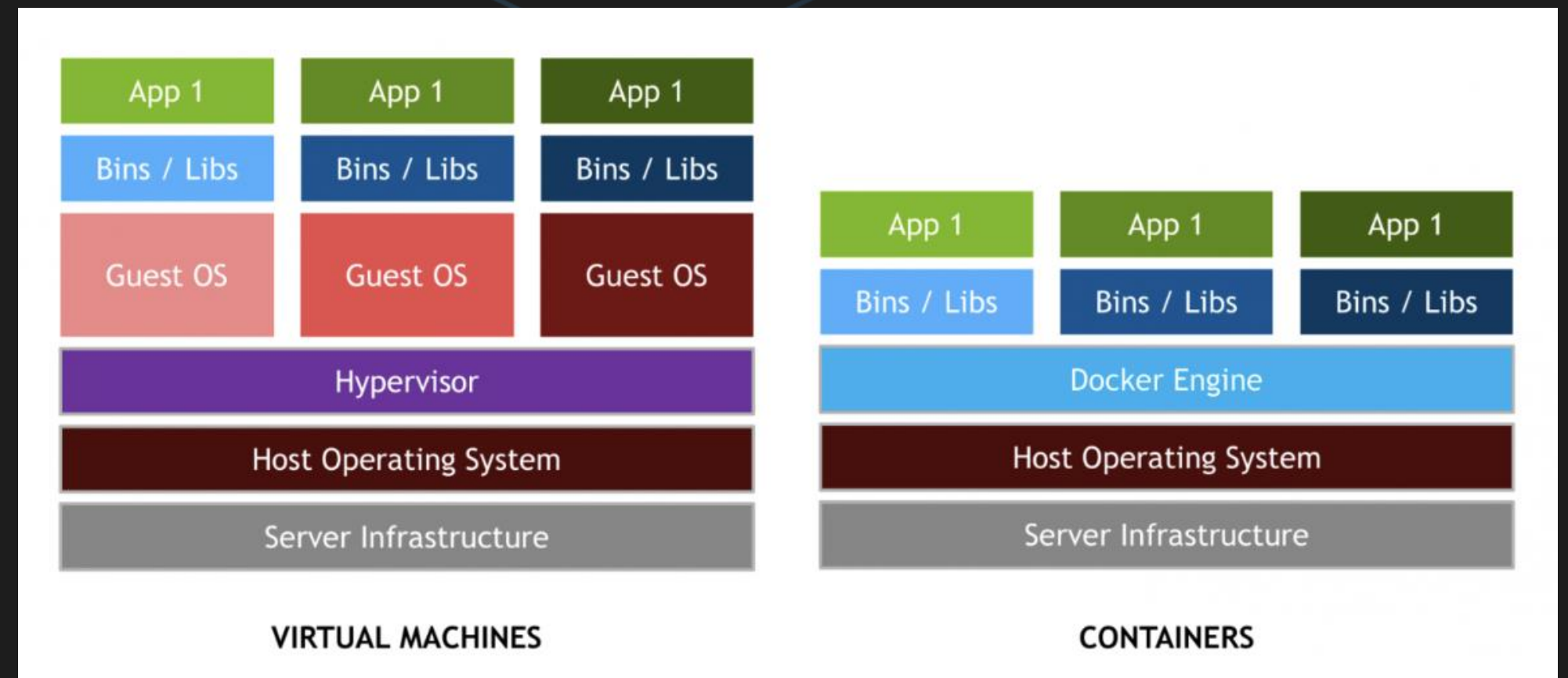
2. Ejecución: Permisos restringidos y monitoreo.

3. Eliminación: Limpieza de datos residuales. **Ejemplo práctico:**

- *Creación:* Usar Alpine Linux vs. Ubuntu (ejercicio comparativo). **Nota:** Profundizar en cada fase en las siguientes diapositivas
-

Creación de Contenedores

- **Imágenes base:** Repositorios oficiales (Docker Hub, GCR).
- **Ejemplo:** Vulnerabilidad Heartbleed en OpenSSL desactualizado.
- **Ejercicio Práctico:** Crear imagen con Alpine Linux y escanear con Trivy.



Ejecución de Contenedores

- **Aislamiento:** SELinux, AppArmor.
- **Redes:** Políticas de acceso restringido.
- **Ejercicio Práctico:** Configurar perfil de AppArmor para Nginx.

```
test@test-virtual-machine: ~  
test@test-virtual-machine:~$ sudo aa-status  
apparmor module is loaded.  
46 profiles are loaded.  
44 profiles are in enforce mode.  
/snap/core/12834/usr/lib/snapd/snap-confine  
/snap/core/12834/usr/lib/snapd/snap-confine//mount-namespace-capture-helper  
/snap/snapd/15177/usr/lib/snapd/snap-confine  
/snap/snapd/15177/usr/lib/snapd/snap-confine//mount-namespace-capture-helper  
/snap/snapd/15534/usr/lib/snapd/snap-confine  
/snap/snapd/15534/usr/lib/snapd/snap-confine//mount-namespace-capture-helper  
/usr/bin/evince  
/usr/bin/evince-previewer  
/usr/bin/evince-previewer//sanitized_helper  
/usr/bin/evince-thumbnailer  
/usr/bin/evince//sanitized_helper  
/usr/bin/man  
/usr/lib/NetworkManager/nm-dhcp-client.action  
/usr/lib/NetworkManager/nm-dhcp-helper  
/usr/lib/connman/scripts/dhclient-script  
/usr/lib/cups/backend/cups-pdf  
/usr/lib/snapd/snap-confine  
/usr/lib/snapd/snap-confine//mount-namespace-capture-helper  
/usr/sbin/cups-browsed  
/usr/sbin/cupsd
```

Eliminación Segura

- **Volúmenes persistentes:** Riesgo de fugas de información.
- **Ejercicio Práctico:** Eliminar contenedor y verificar volúmenes.

Capacidades de Linux

Ejemplos

`CAP_NET_ADMIN`

`CAP_SYS_ADMIN`

Ejercicio Práctico: Configurar Nginx con .

`NET_BIND_SERVICE`



Herramientas de Escaneo

- Herramientas: Trivy, Anchore, Clair.
- Ejercicio Práctico: Integrar Trivy en GitHub Actions.

•

zachroofsec/trivy-tutorial1 (debian 9.13)

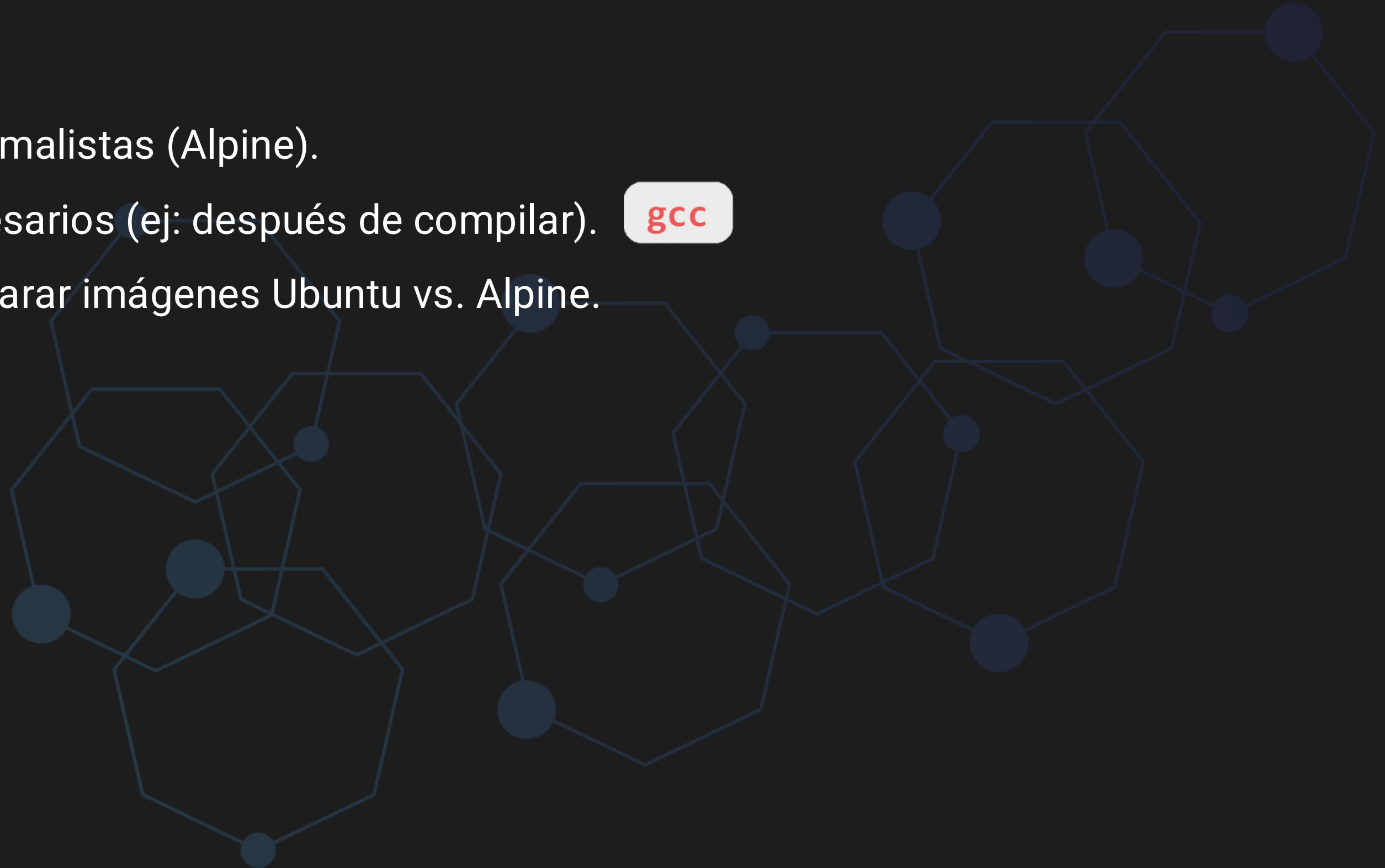
Total: 485 (UNKNOWN: 6, LOW: 118, MEDIUM: 169, HIGH: 177, CRITICAL: 15)

Library	Vulnerability	Severity	Installed Version	Fixed Version	Title	
binutils	CVE-2017-12448	HIGH	2.28-5		binutils: heap use after free in bfd_cache_close function https://avd.aquasec.com/nvd/cve-2017-12448	
	CVE-2017-12449				binutils: out of bounds heap read in _bfd_vms_save_sized_string function https://avd.aquasec.com/nvd/cve-2017-12449	
	CVE-2017-12450				binutils: out of bounds heap write in alpha_vms_object_p function https://avd.aquasec.com/nvd/cve-2017-12450	
	CVE-2017-12451				binutils: out of bounds stack read in _bfd_xcoff_read_ar_hdr function https://avd.aquasec.com/nvd/cve-2017-12451	
	CVE-2017-12452				binutils: out of bounds heap read in bfd_mach_o_i386_canonicalize_one_reloc function https://avd.aquasec.com/nvd/cve-2017-12452	
	CVE-2017-12453				binutils: out of bounds heap read in __bfd_vms_slurp_eeom function https://avd.aquasec.com/nvd/cve-2017-12453	
	CVE-2017-12454	MEDIUM			binutils: Arbitrary memory read in _bfd_vms_slurp_egs function https://avd.aquasec.com/nvd/cve-2017-12454	
	CVE-2017-12455			3.11	binutils: out of bounds heap read in evax_bfd_print_emh function https://avd.aquasec.com/nvd/cve-2017-12455	
	CVE-2017-12456			3.11	binutils: out of bounds heap read in read_symbol_stabs_debugging_inf function https://avd.aquasec.com/nvd/cve-2017-12456	
	CVE-2017-12457			3.11	binutils: NULL pointer dereference in bfd_make_section_with_flags function https://avd.aquasec.com/nvd/cve-2017-12457	
	CVE-2017-12458	CRITICAL			binutils: out of bounds heap read in nlm_swap_auxiliary_headers_in function https://avd.aquasec.com/nvd/cve-2017-12458	

Construcción de Imágenes Seguras

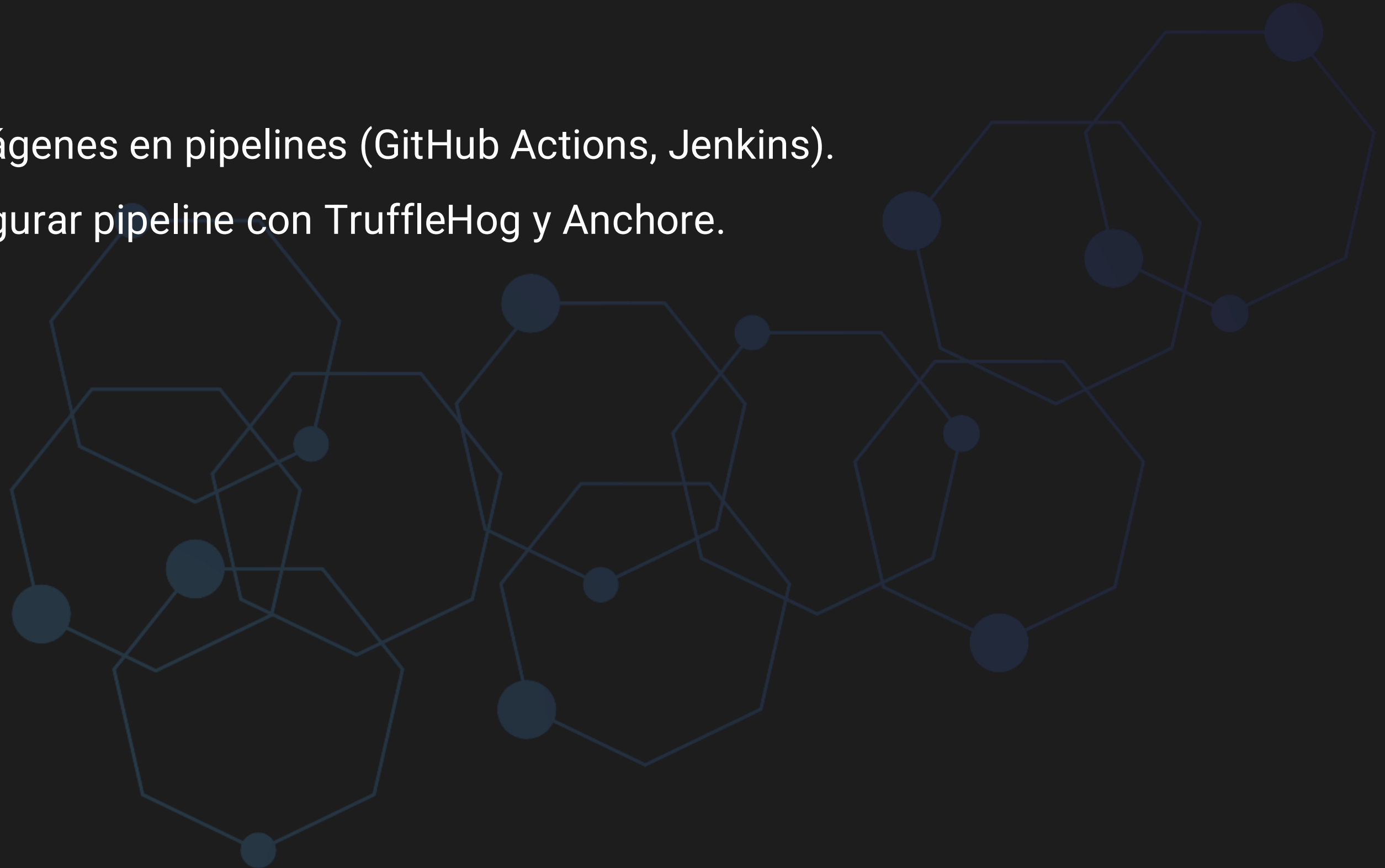
- **Prácticas:** Imágenes minimalistas (Alpine).
- Eliminar paquetes innecesarios (ej: después de compilar).
- **Ejercicio Práctico:** Comparar imágenes Ubuntu vs. Alpine.

gcc



Políticas de Seguridad en CI/CD

- **Validación:** Escanear imágenes en pipelines (GitHub Actions, Jenkins).
- **Ejercicio Práctico:** Configurar pipeline con TruffleHog y Anchore.



Conclusión

- **Clave:** Imágenes base confiables, escaneo continuo, permisos mínimos.
- **Llamado a la acción:**
 - Explorar herramientas (Falco, Cosign).
 - Unirse a comunidades de seguridad en la nube. **Nota:** Preguntas y respuestas y discusión abierta.

Preguntas

- Logotipo de contacto/soporte.
- Enlace a recursos adicionales (documentación de Trivy, Anchore, etc.).

